

PRIVACY RISK ASSESSMENT

CertScore Data Security & Privacy Risk Assessment

DPIA-style baseline review and recurring governance procedure

Field	Value
Document	CS-PRIV-RA-001
Version	1.0
Assessment date	August 23, 2026
Assessment scope	WC01 production application and supporting AWS environment
Assessment status	Completed baseline - effective upon accountable owner approval
Next full review	August 23, 2027, or earlier upon a material trigger

Outcome: Overall residual privacy risk is Moderate. Processing may continue subject to the remediation plan, quarterly control reviews, and accountable owner approval. No legal compliance certification is asserted.

Approval and adoption

This assessment becomes the organization's operative baseline when an accountable owner signs below. Approval also adopts the recurring review procedure in Section 10. An unsigned draft alone is not sufficient evidence that regular organizational reviews are performed.

Approval field	Entry
Accountable owner	_____
Title	_____
Decision	Approve / Approve with conditions / Return for revision
Signature	_____
Date	_____

1. Executive determination

CertScore operates a public website-scanning and reporting service. The app processes account and organization identifiers, operational telemetry, privacy-request details, and retained public-web evidence. Some public-web evidence may incidentally contain personal data. Optional analytics may process cookie, device, and interaction data after consent.

The review found meaningful technical controls, including scoped AWS identities, network restrictions, TLS configuration, consent-gated analytics, privacy-request intake, self-service account deletion, bounded evidence contracts, redaction, and scheduled vulnerability scanning. The principal residual risks are incomplete retention rules, manual privacy-request case management, processor and international-transfer governance, and the possibility that retained public-web evidence contains personal data beyond what is necessary.

Decision: Continue processing with a Moderate residual-risk rating. Complete Priority 1 actions by September 30, 2026 and retain evidence of quarterly reviews.

Scope and boundaries

- In scope: certscore.ai web application, API/MCP surfaces, PostgreSQL records, AWS S3 artifacts, application logs, account authentication, privacy-request intake, consent-gated analytics, WC01-managed scanner orchestration, and model-assisted policy review inputs/outputs where enabled.
- Out of scope: scanner runtime behavior owned by the separate WS01 repository, customers' internal systems, and legal conclusions about scanned third-party websites.
- Evidence basis: repository configuration and code available on August 23, 2026. Live cloud settings, vendor contracts, retention jobs, and operational practice require owner verification.

Assessment limitations

This is a privacy engineering and governance assessment, not legal advice, a certification, or an independent audit. Controls described as 'implemented' are supported by repository evidence; controls described as 'verify' or 'planned' must not be represented as operating until evidence is retained.

2. Processing inventory

Activity	Data subjects	Data / content	Purpose	Systems / processors
Accounts and access	Users and workspace members	Email, name, auth provider, role, session/account records	Authentication, authorization, service administration	PostgreSQL; authentication service
Public website scans	Website operators, authors, public-site visitors incidentally	URLs, hostnames, public page content, screenshots, policy excerpts, cookies/storage names, network and vendor observations	Produce risk-signal reports and retained evidence	AWS Lambda/ECS; S3; PostgreSQL
Operational security	Users, API callers, site visitors	Timestamps, routes, coarse technical context, security and activity events; bounded identifiers	Security, abuse prevention, reliability, auditability	Application logs; CloudWatch; PostgreSQL

Activity	Data subjects	Data / content	Purpose	Systems / processors
Analytics	Site visitors who allow optional analytics	Cookie/device identifiers, usage events, masked session-insight data	Understand product usage and reliability	Google Analytics; Microsoft Clarity, if enabled
Privacy and support requests	Requesters and authorized agents	Email, name, jurisdiction, identifiers, request details, verification status	Verify and fulfill rights/support requests	Gmail/Google Workspace; manual workflow
Model-assisted review	Public-site authors or individuals incidentally present in bounded evidence	Retained policy excerpts and structured evidence; redacted/bounded outputs	Extraction and internal/approved policy review	Configured model provider; WC01 artifacts

Data minimization and prohibited content

- The product is not intended to collect credentials, payment-card data, health data, government identifiers, raw request/response bodies, or unbounded private content.
- Evidence contracts require bounded, typed, display-safe projections and prohibit carrying raw cookies, sensitive query values, and raw model reasoning into reviewer or web-facing artifacts.
- Public-web capture can still incidentally include names, contact details, faces, or other personal data. Minimization and retention controls therefore remain necessary even when source material is public.

Purposes and preliminary lawful-basis map

Purpose	Candidate basis	Required validation
Provide accounts and reports	Contract / steps requested by user	Confirm terms and jurisdiction-specific applicability
Security, abuse prevention, service reliability	Legitimate interests	Document balancing and ensure bounded logging
Optional analytics and session insight	Consent	Validate that tags remain blocked until valid consent and withdrawal works
Privacy-rights fulfillment	Legal obligation / legitimate interests	Apply the requester's jurisdiction and verification standard
Public-web evidence collection	Legitimate interests; customer instructions where applicable	Complete a balancing assessment; minimize incidental personal data

3. Necessity and proportionality

The core scan requires public URLs, observable browser behavior, and enough retained evidence to substantiate findings. Retention is necessary for report reproducibility, dispute handling, and evidence quality, but the current policy does not define a complete category-by-category schedule. A documented schedule and deletion verification are therefore required.

Proportionality findings

Principle	Assessment	Evidence / gap
Purpose limitation	Partially met	Canonical evidence-to-finding pipeline limits display-layer inference; verify secondary uses of artifacts.
Data minimization	Partially met	Typed/bounded artifacts and redaction are strong; define screenshot and public-text minimization review.
Accuracy	Met with caveats	Fail-closed unknown/review states reduce overclaiming; requesters need a correction path.
Storage limitation	Gap	Policy is purpose-based but lacks a complete retention schedule and deletion evidence.
Security	Partially met	AWS controls and vulnerability process exist; live settings and open High advisories require tracking.
Transparency and rights	Met with caveats	Privacy notice and request form cover core rights; manual case tracking and response evidence need formalization.

Privacy rights capability

Right	Capability	Operational dependency
Access / portability	Available by public request form and email	Manual verification and fulfillment
Deletion	Public request plus authenticated self-service account deletion	Company-owned scan/workspace records may remain; document exceptions
Correction	Available by public request form	Manual fulfillment; profile self-service is not comprehensive
Restriction / objection	Available by public request form	Manual fulfillment and processor follow-through
Consent withdrawal	Cookie preferences path described	Quarterly production validation required

DPIA screening

Criterion	Result	Rationale
Systematic monitoring of individuals	Limited	The product systematically observes public websites, not intended individual behavior; optional analytics monitors product use.
Large-scale special-category data	No intended processing	Public evidence may incidentally contain sensitive context; contracts prohibit unbounded sensitive payloads.
Automated decisions with legal/significant effect	No	Findings are risk signals and review aids, not legal certification or decisions about individuals.
New technology / model assistance	Yes	Bounded model-assisted review is used or planned with strict schemas, provenance, validation, and fail-closed states.
Vulnerable individuals / children	Not targeted	No child-directed service; incidental public content remains possible.
Cross-border processing	Yes	US-operated service and third-party processors may process data in multiple countries.

Screening conclusion: A formal statutory DPIA is not clearly mandatory on the current evidence, but the use of public-web evidence, optional interaction analytics, model assistance, and cross-border processors warrants this documented privacy risk assessment and trigger-based DPIA re-screening.

4. Existing safeguards

Control domain	Safeguard	Status / limitation
Access control	Separate/scoped AWS task roles, organization roles, authenticated settings, and security-group boundaries.	Implemented in code/laC; verify deployed parity
Network and transport	Internet-facing ALB, TLS certificate/HTTPS redirection when configured, WAF, source-IP rate limiting, and restricted ECS ingress.	Implemented in laC; common WAF rule group is count-only
Secrets	AWS Secrets Manager references and task-role access rather than checked-in production secrets.	Implemented in laC
Evidence minimization	Typed, bounded, provenance-preserving evidence; redaction of sensitive query values and prohibition on raw reasoning in web artifacts.	Implemented by architecture and contracts
Rights handling	Public DSAR form supports access, deletion, correction, portability, objection, and restriction; email fallback; self-service account deletion.	Implemented; fulfillment is manual
Consent	Optional analytics described as consent-gated with preference changes available.	Implemented intent; production behavior needs recurring evidence
Vulnerability management	Quarterly Trivy scan, weekly dependency review procedure, severity SLAs, and vulnerability register.	Program established; open High advisories tracked
Recovery	Documented backup/restore procedure and test cadence.	Procedure exists; live backup evidence requires operator verification

5. Privacy risk register

Scoring uses Likelihood (L) and Impact (I), each from 1 to 5. Score = L x I. Low: 1-4; Moderate: 5-9; High: 10-15; Critical: 16-25. Residual ratings assume repository-evidenced controls operate as designed; items requiring live verification remain actions.

ID	Risk event	Affected people	Inherent	Existing safeguards	Residual
R1	Account or administrative access is compromised	Users and workspace members	3x4=12 High	Scoped IAM, roles, sessions, secrets management, SGs	2x3=6 Moderate
R2	Scan artifacts capture more incidental personal data than necessary	People represented on public sites	3x4=12 High	Bounded contracts, redaction, display-safe projection	2x4=8 Moderate
R3	Records are retained too long or deletion is incomplete	All data subjects	3x4=12 High	Account deletion and manual DSAR path; purpose-based policy	3x3=9 Moderate
R4	Analytics/session insight collects before consent or exposes entered data	Site visitors	3x4=12 High	Consent intent, preference controls, masking	2x3=6 Moderate
R5	Manual privacy requests are delayed, lost, or fulfilled inaccurately	Requesters	3x3=9 Moderate	Public form, unique request ID, verification fields, email fallback	2x3=6 Moderate
R6	Processor or international-transfer terms are incomplete or drift	All affected subjects	3x4=12 High	Vendor references and policy disclosure; scoped providers	3x3=9 Moderate
R7	Model provider receives excessive or unverified personal data	People in retained public evidence	2x5=10 High	Bounded inputs, redaction, hashes, schemas, validation, fail-closed output	2x3=6 Moderate
R8	Logs or API activity reveal identifiers, URLs, or secrets	Users, callers, public-site subjects	3x3=9 Moderate	Structured logging rules, bounded/HMAC identifiers, secret-handling rules	2x3=6 Moderate
R9	Known vulnerabilities enable unauthorized data access	All data subjects	3x4=12 High	Quarterly Trivy, weekly review, SLAs, register, immutable images	2x4=8 Moderate
R10	Backup, restore, or incident response exposes or loses personal data	All data subjects	2x5=10 High	DR procedure, encryption requirements, versioning, scoped incident roles	2x3=6 Moderate

Risk treatment decision

- No Critical residual risk was identified from repository evidence.
- All Moderate residual risks are accepted temporarily only with the action plan below and quarterly evidence review.
- Any discovery of special-category data at scale, child-directed processing, employee monitoring, biometric identification, or automated decisions about individuals triggers a new DPIA before processing continues.

6. Remediation and evidence plan

ID	Priorty	Action	Owner	Due	Closure evidence
A1	P1	Approve a category-by-category retention and deletion schedule covering DB, logs, S3 evidence, analytics, Gmail requests, backups, and legal holds.	Product owner + Engineering	2026-09-30	Signed schedule; deletion-test evidence
A2	P1	Create a privacy-request case register with received, verification, scope, deadline, decision, systems searched, processor notices, fulfillment, and closure evidence.	Product owner	2026-09-15	Request register and one dry-run record
A3	P1	Confirm processor inventory, DPAs, subprocessors, regions, transfer mechanisms, and deletion/return terms for AWS, Google, Microsoft, and any model provider.	Product owner	2026-09-30	Approved processor register
A4	P1	Run and retain a production test proving optional analytics and Clarity do not load before consent, sensitive fields are masked, and withdrawal takes effect.	Engineering	2026-09-15	Test artifact and remediation issue if failed
A5	P2	Document legitimate-interest balancing for public-web evidence and security logging, including necessity, impact, safeguards, and opt-out/objection handling.	Product owner	2026-10-31	Signed balancing assessments
A6	P2	Verify live encryption, S3 public-access blocks, RDS backups, log retention, and access permissions; record configuration evidence without secrets.	AWS operator	2026-10-31	Dated control checklist
A7	P2	Resolve or formally accept open High dependency advisories under the existing vulnerability SLA.	Engineering + Product owner	Per security register	Clean scan or dated risk acceptance
A8	P2	Add a privacy review checkbox and data-flow note to material feature/change review, including model/API and new vendor changes.	Engineering	2026-10-31	PR template or change record

Cost control: This document creates no recurring infrastructure or paid-service cost. Any remediation expected to add \$1/month or more requires separate product-owner approval with cost, benefit, and lower-cost alternatives.

7. Data lifecycle requirements

1. Collect only the data categories needed for an approved purpose and contract. Do not introduce raw payloads, credentials, sensitive query values, or unbounded content into retained artifacts.
2. Classify new fields before release: subject, purpose, source, sensitivity, processor, location, retention, access roles, deletion method, and downstream projections.
3. Apply the approved retention schedule through service-owned deletion or lifecycle controls, preserving only documented legal, security, billing, dispute, and evidence-integrity exceptions.
4. On deletion or restriction, identify every relevant system and processor, document exceptions, verify completion, and retain only a minimal request/audit record for the approved period.
5. Test lifecycle controls at least annually and after material storage, schema, vendor, or backup changes.

8. Privacy-request operating procedure

Stage	Required activity
1. Intake	Assign or retain the DSAR identifier; record received date, request type, contact, jurisdiction, and requested scope.
2. Triage	Calculate the response deadline, identify applicable law/contract, and flag urgent restriction, objection, or security issues.
3. Verify	Use proportionate verification. Do not collect more identification than necessary. Validate authorized-agent authority.
4. Locate	Search account/auth records, memberships, scans/artifacts, API activity, analytics/support systems, email, backups, and relevant processors.
5. Decide	Document what can be fulfilled, corrected, deleted, restricted, exported, or lawfully retained, with a reason for each exception.
6. Execute	Apply changes in source systems and notify processors where required. Preserve company-owned records only when a documented basis applies.
7. Verify	Confirm completion with system evidence and a second-person check for material or complex requests.
8. Respond and close	Send a clear response, provide appeal/complaint information where applicable, and retain the minimal case record under the approved schedule.

9. Incident and breach considerations

A privacy incident includes unauthorized access, disclosure, alteration, loss, overcollection, unapproved processing, failed deletion/restriction, or processor misuse involving personal data. The incident lead must preserve evidence, identify affected data subjects and jurisdictions, contain processing, and document notification decisions and timing. Regulatory or individual notification requires qualified legal review when thresholds may be met.

10. Recurring privacy review procedure

Adopted cadence: Quarterly privacy control review; annual full privacy risk assessment; and trigger-based review before material processing changes. The first quarterly evidence review is due October 15, 2026.

Review	Timing	Minimum scope	Owner	Evidence
Quarterly	January, April, July, October	Review DSAR register, analytics consent test, processor changes, retention/deletion evidence, incidents, vulnerability findings, access changes, and open actions.	Product owner; Engineering provides evidence	Signed review log and linked evidence
Annual full assessment	By August 23 each year	Refresh data map, purposes/bases, necessity, DPIA screening, risk scores, safeguards, processor inventory, retention, rights, incidents, and action plan.	Product owner accountable	Approved assessment version
Change-triggered	Before material change	New data category, sensitive data, monitoring/analytics, model/provider, purpose, region, processor, sharing, retention, identity/biometric use, child-directed feature, or automated decision.	Feature owner + Product owner	PR/change record and updated assessment if material
Incident-triggered	After material privacy/security incident	Reassess affected flows and controls; update risks and actions after containment and lessons learned.	Incident lead + Product owner	Post-incident privacy review

Quarterly review checklist

- Confirm the data inventory, processors, regions, purposes, and public privacy notice remain accurate.
- Review privacy requests, deadlines, verification, fulfillment evidence, complaints, and recurring failure patterns.
- Verify retention/deletion jobs and one representative deletion across primary records and documented downstream systems.
- Test consent gating, withdrawal, and masking for optional analytics/session-insight tools.
- Review incidents, security findings, access changes, new vendors/models, and material product changes for privacy impact.
- Update this risk register and assign due dates for any control drift; obtain dated owner acceptance for overdue risk.

11. Evidence register

Ref	Evidence	Repository location	Supports
E1	Privacy notice	apps/web/app/privacy/page.tsx	Rights, retention framing, analytics, transfers, contact
E2	Privacy request form	apps/web/components/privacy/privacy-request-form.tsx	Access, deletion, correction, portability, objection/restriction
E3	Privacy request routing	apps/web/server/privacy-request/send-privacy-request.ts	Validation, request ID, verification path, email routing
E4	Self-service account deletion	apps/web/server/settings/account-actions.ts	Authenticated deletion and confirmation
E5	AWS web controls	infra/aws/web-ecs/main.tf	IAM roles, Secrets Manager, SGs, TLS/ALB, WAF, container setting
E6	Quarterly vulnerability scan	.github/workflows/quarterly-vulnerability-scan.yml	Trivy dependency and IaC scan cadence
E7	Security operations	docs/security-operations.md	Patch SLAs, supported software, scan review, change approval requirements
E8	Vulnerability register	docs/security-vulnerability-register.md	Baseline findings and remediation tracking
E9	Disaster recovery	docs/disaster-recovery.md	Backup/restore expectations, incident roles, verification cadence
E10	Repository governance	AGENTS.md	Cost approval, evidence discipline, data minimization, model-review safeguards

Required operational evidence not established by repository

- Signed processor register, DPAs, transfer mechanism records, and current subprocessor review.
- Live AWS screenshots/exports confirming encryption, backup retention, public-access blocks, deployed WAF behavior, and log retention.
- Completed privacy-request register or dry-run, deletion verification, and response-deadline tracking.
- Production consent/masking/withdrawal test for analytics and session-insight tools.
- Signed owner adoption of this assessment and quarterly/annual review cadence.

12. Questionnaire response

Use after approval: Yes. CertScore performs quarterly privacy control reviews, an annual data security and privacy risk assessment, and change-triggered reviews before material changes to personal-data processing. The baseline assessment was completed on August 23, 2026 and is tracked through a documented remediation and evidence plan.

Before the accountable owner signs this assessment and adopts the cadence, the truthful response remains No. Retain the signed version, quarterly review logs, and linked evidence so the answer remains supportable over time.

Appendix A - Quarterly privacy review record

Field	Record
Review period	_____
Review date	_____
Reviewer(s)	_____
Processor/data-flow changes	None / See attached change list
Privacy requests reviewed	Count: _____ Overdue: _____ Exceptions: _____
Consent and masking test	Pass / Fail / Not used Evidence: _____
Retention/deletion verification	Pass / Fail Evidence: _____
Incidents or complaints	None / See attached record
Open risks/actions	_____
Decision	Continue / Continue with actions / Pause affected processing
Owner signature/date	_____

Appendix B - Change-trigger screening

- ☐ New category of personal or sensitive data
- ☐ New purpose, disclosure, sale/share, or processor
- ☐ New analytics, session replay, profiling, AI/model, biometric, or monitoring capability
- ☐ New country/region or international transfer
- ☐ Material increase in scale, retention, identifiability, or data-subject impact
- ☐ Processing involving children, employees, vulnerable people, or legal/significant decisions
- ☐ Material privacy/security incident or control failure

If any box is checked, record the change owner, affected flow, safeguards, and decision. Complete a new or updated DPIA/privacy risk assessment before processing when risk may be high.